Enterprise Cloud Security & Access Control Guide

Configuring Access and Permissions in Google Cloud Platform

A Comprehensive Enterprise Architecture Guide for Identity & Access Management (IAM), Least Privilege Enforcement, Service Accounts, and Security Governance

Author: Cloud Infrastructure & Enterprise Security Architecture Team

Platform: Google Cloud Platform (GCP) IAM & Cloud Identity

Target Audience: Security Engineers, Cloud Administrators, DevOps Engineers

Document Version: 3.0 (2026 Edition)

Table of Contents

Module 1: Fundamentals of Cloud Identity & Access Management (IAM)

Module 2: GCP Access Control Structure & Principal Types

Module 3: Deep Dive into IAM Roles: Basic, Predefined & Custom Roles

Module 4: Implementing Principle of Least Privilege (PoLP)

Module 5: Configuring Service Accounts, Keys, and Short-Lived Credentials

Module 6: IAM Conditions, Resource Boundaries & Policy Inheritance

Module 7: Workload Identity Federation for Cross-Cloud Access

Module 8: Step-by-Step Practical Configurations (Console, gcloud CLI & Terraform)

Module 9: Auditing Access, Cloud Logging, and Security Command Center

Module 10: Production Security Governance & Compliance Checklist

Module 1: Fundamentals of Cloud IAM

1.1 Introduction to Identity & Access Management

Identity and Access Management (IAM) is the central security governance layer of Google Cloud Platform (GCP). It controls **WHO** (identity) can do **WHAT** (permission) on **WHICH** resource (scope). Proper access and permission configuration prevents unauthorized data access, reduces security blast radius, and ensures compliance with global standards such as SOC2, ISO27001, and HIPAA.

1.2 Core Pillars of Access Control

Modern cloud security relies on four main pillars to enforce robust security posture:

- **Authentication (AuthN):** Verifying the identity of a user, service account, or application attempting to access resources.
- **Authorization (AuthZ):** Determining whether an authenticated identity possesses the necessary permissions to execute a specific API call.
- **Auditability:** Maintaining detailed log trails of every access attempt, permission change, and resource modification.
- **Least Privilege Enforcement:** Granting users and workloads only the minimal access needed to complete designated tasks.

> **Security Insight**
>
> In cloud environments, identity is the new security perimeter. Protecting IAM policy definitions and service account credentials is as critical as securing network firewalls.

Module 2: GCP Access Control Structure & Principal Types

2.1 Understanding IAM Principals

In GCP, a principal is an entity that can be granted access to a resource. GCP categorizes principals into five distinct types:

Principal Type	Identifier Format	Primary Use Case
Google Account	`user@gmail.com` or domain email	Individual developers, team members, administrators
Service Account	`app-runner@project.iam.gserviceaccount.com`	Applications, background jobs, automated CI/CD pipelines
Google Group	`devops-team@company.com`	Managing permissions at scale across organized teams
Google Workspace Domain	`domain:company.com`	Granting permissions to all employees within an organization
Cloud Identity Domain	`domain:company.org`	Enterprise directory synchronization without full Workspace suite

2.2 IAM Policy Structure

An IAM Policy is a collection of bindings that link one or more principals to specific roles. Formally represented in JSON format:

```
{
  "bindings": [
    {
      "role": "roles/storage.objectViewer",
      "members": [
        "user:alice@example.com",
        "group:data-analysts@example.com"
      ]
    },
    {
      "role": "roles/compute.instanceAdmin.v1",
      "members": [
        "serviceAccount:ci-cd-deployer@my-project.iam.gserviceaccount.com"
      ]
    }
  ]
}
```

Module 3: Deep Dive into IAM Roles

3.1 Classification of IAM Roles

GCP categorizes permissions into three primary role categories to balance flexibility and security control:

1. Basic (Primitive) Roles

Legacy roles created during early GCP generations. These provide broad, coarse-grained access across all services within a project:

- **Owner (`roles/owner`):** Full access to all resources, permissions configuration, and billing controls.
- **Editor (`roles/editor`):** Full modification access to resources, but cannot modify permissions or billing.
- **Viewer (`roles/viewer`):** Read-only access to inspect existing resources.

> **Production Warning**
>
> Avoid granting Basic Roles (Owner/Editor/Viewer) in production environments. Their scopes are overly broad and pose substantial security risks. Use Predefined or Custom Roles instead.

2. Predefined Roles

Fine-grained roles created and maintained by Google for specific products (e.g., `roles/pubsub.publisher`, `roles/bigquery.dataEditor`). Google updates these automatically when new service capabilities are introduced.

3. Custom Roles

Developer-defined roles tailored to exact business needs by aggregating specific permissions (e.g., `resourcemanager.projects.get` + `storage.buckets.list`).

Module 4: Principle of Least Privilege (PoLP)

4.1 Enforcing Least Privilege Access

The Principle of Least Privilege dictates that every module, user, and service account must be able to access only the information and resources necessary for its legitimate purpose.

```
+---------------------------------------------------------------------+
| Over-Privileged State (Risky) |
| User -> Granted 'roles/editor' -> Access to ALL Resources |
+---------------------------------------------------------------------+
|
v
+---------------------------------------------------------------------+
| Least-Privilege State (Secure) |
| User -> Granted 'roles/storage.objectViewer' -> Read Bucket Only |
+---------------------------------------------------------------------+
```

4.2 Using IAM Recommender for Access Optimization

Google Cloud includes an automated ML tool called **IAM Recommender**. It automatically analyzes historical access logs, detects unused permissions over 90-day windows, and generates actionable recommendations to shrink oversized permissions without breaking workflows.

Module 5: Configuring Service Accounts & Key Management

5.1 Service Accounts Architecture

Service Accounts are special identities used by applications and virtual machine instances rather than human users. They do not have passwords and authenticate using key pairs or OAuth tokens.

5.2 Service Account Key Risks vs. Short-Lived Credentials

Downloading static JSON private keys poses significant security risks if leaked into source repositories. Enterprise standards enforce short-lived credentials via Application Default Credentials (ADC) or Identity Token Impersonation.

```
# Example: Impersonating a Service Account via gcloud CLI without downloading keys
gcloud config set auth/impersonate_service_account production-runner@my-
project.iam.gserviceaccount.com
```

Module 6: IAM Conditions & Policy Inheritance

6.1 Policy Inheritance Hierarchy

Permissions granted at parent nodes in the GCP hierarchy automatically flow down to all child resources:

Organization Node > Folders > Projects > Resources

Child policies combine with parent policies additively. Access granted at a higher level cannot be revoked at a lower level.

6.2 IAM Conditions (Attribute-Based Access Control)

IAM Conditions allow administrators to grant permissions conditionally based on attributes like time, request origin IP, or resource tags.

```
# Conditional binding example: Allow access only during working hours
"condition": {
  "title": "Business_Hours_Only",
  "description": "Restrict access to standard work hours UTC",
  "expression": "request.time.getHours('UTC') >= 8 && request.time.getHours('UTC') < 18"
}
```

Module 7: Workload Identity Federation

7.1 Eliminating Service Account Keys for External Workloads

Workload Identity Federation allows workloads running outside GCP (e.g., AWS, Azure, GitHub Actions, Terraform Cloud) to authenticate directly to GCP services using OpenID Connect (OIDC) or SAML 2.0 without static service account keys.

```
[GitHub Actions CI/CD] --(1. Requests OIDC Token)--> [GitHub OIDC Provider]
[GitHub Actions CI/CD] --(2. Exchanges Token)-----> [GCP Workload Identity Federation]
[GCP Workload Identity] -(3. Issues Short-Lived)--> [GCP IAM Token for Service Account]
```

Module 8: Step-by-Step Practical Configurations

8.1 Granting IAM Permissions via Console

1. In GCP Console, open **IAM & Admin > IAM**.
2. Click **GRANT ACCESS** at the top panel.
3. In **New principals**, enter user email or group ID.
4. Select appropriate role from dropdown (e.g., `Vertex AI User`).
5. Click **SAVE**.

8.2 Managing IAM via gcloud CLI

```
# Granting a role to a user
gcloud projects add-iam-policy-binding my-project-id     --
member="user:developer@example.com"     --role="roles/viewer"

# Creating a Custom Role
gcloud iam roles create customAppRunner     --project=my-project-id     --title="Custom App
Runner"     --permissions="storage.buckets.list,storage.objects.get"
```

8.3 Infrastructure as Code via Terraform

```
# Terraform IAM Binding Example
resource "google_project_iam_binding" "storage_viewer" {
  project = "my-project-id"
  role    = "roles/storage.objectViewer"

  members = [
    "user:analyst@example.com",
    "group:data-team@example.com",
  ]
}
```

Module 9: Auditing Access & Security Command Center

9.1 Cloud Audit Logs

Google Cloud records three primary types of audit logs automatically:

- **Admin Activity Logs:** Records administrative modifications to project settings or IAM policies.
- **Data Access Logs:** Tracks API calls that read or write user-provided data (e.g., Cloud Storage object downloads).
- **System Event Logs:** Records automated GCP system actions.

9.2 Security Command Center (SCC)

SCC provides real-time vulnerability management, misconfiguration detection, and unauthorized IAM grant alerts across all project resources.

Module 10: Governance & Compliance Checklist

10.1 Access Control Production Checklist

1. Enforce 2-Step Verification (2SV) for all user accounts across the Organization domain.
2. Remove Basic Roles (Owner/Editor) from all service accounts and non-administrative staff.
3. Disable Service Account key creation policies using GCP Organization Policies.
4. Utilize Workload Identity Federation for all external CI/CD pipelines.
5. Perform monthly IAM Recommender reviews to eliminate stale access permissions.